Adaptive Quantum-Safe Security and Privacy for Healthcare Data

Jose Rohit M and Karthikeyan Jayaraman
SCORE, Vellore Institute of Technology, Vellore, India

Draft, October 2026

Abstract

Hospitals must protect patient data against future quantum attacks and also de-identify it for secondary use, yet stronger protection costs time: NIST-standardised post-quantum objects (ML-KEM, ML-DSA) are one to two orders of magnitude larger than classical ones, which threatens the roughly 200 ms delivery SLA of streaming IoMT telemetry on congested links. Existing work treats these concerns separately: PQC migration and crypto-agility studies address algorithms and processes, runtime-adaptive IoMT security does not adapt data privacy, and adaptive differential-privacy controllers have no cryptographic dimension. We present Agile-HQ-PQC, a gateway whose controller, CADA-AASM, selects the strongest protection the network can currently afford—transport cryptography *and* privacy parameters together—from a live latency budget $L = 200 - \mathrm{RTT} - 0.5\,\mathrm{CPU}$, with a persistence filter against cipher flapping and a hard floor (NIST Category 3) for raw clinical telemetry. In a 30-trial paired evaluation under an *emulated* congestion model, steering reduced SLA violations during stress relative to static Tier 5 (clinical 7.4% → 4.1%, research 6.9% → 2.9%, both $p < 10^{-4}$), was statistically indistinguishable from static Tier 3 while running the strongest suite in calm periods, and cut tier changes by 65%. The benefit is concentrated on constrained links (-45 pp at 1 Mbps) and vanishes at $\geq$ 5 Mbps; batch ML-DSA signing alone removes most of the latency problem. A real-link validation (network namespaces, kernel bandwidth shaping, real TCP) does *not* reproduce the emulated gain at $\geq$ 2 Mbit/s: adaptation matters only on very thin links, where static Tier 5 fails outright but a well-chosen static Tier 3 does as well. We report these negative results alongside the positive ones.

1 Introduction

Adversaries can record encrypted hospital traffic today and decrypt it once a cryptanalytically relevant quantum computer exists ("harvest now, decrypt later"); clinical data such as genomics has a confidentiality horizon of decades, so migration to PQC cannot wait [1, 2]. PQC has an operational cost, however. An ML-DSA-87 signature is 4 627 bytes (Ed25519: 64) and an ML-KEM-1024 ciphertext is 1 568 bytes (X25519: 32), so a signed telemetry packet spans several Ethernet frames, increasing serialisation time and exposure to loss exactly when a hospital network is congested. Streaming ICU telemetry tolerates about 200 ms end to end.

Separately, data leaving the clinical system for secondary use must be de-identified: differential privacy [3] for numeric streams and (K, L)-anonymity [4, 5] for tabular records. Section 2 shows that, in the literature we reviewed, no work adapts transport cryptography and data-privacy strength together under a latency constraint with a compliance floor.

Research question. Can transport security and data privacy be treated as one trade-off, steered by the network's remaining latency budget, without ever dropping raw patient data below a safe minimum?

Contributions. (i) *A joint model*: three protection levels (High/Medium/Low; Tier 5/3/1) that bind KEM, signature, AEAD, ε, K and L together and are chosen by a single latency-budget controller (CADA-AASM). (ii) *A safe adaptive policy*: persistence filtering against flapping and a Category-3 floor for raw PHI; researcher exports additionally enforce $K \geq 5$, $L \geq 3$. (iii) *An honest evaluation*: 30 paired trials, ablations and a bandwidth×loss sweep showing where adaptation helps (constrained links) and where it does not ($\geq$ 5 Mbps, or with batch signing). The open implementation, operator console, tamper lab and tamper-evident audit log support these contributions but are not claimed as research novelty.

2 Related Work

PQC migration and crypto-agility. NIST CSWP 39 [6] surveys crypto-agility as the ability to replace algorithms while maintaining operations; Alif et al. [7] propose a seven-phase migration framework for IoT healthcare (inventory, risk assessment, migration, interoperability) and list agility in dynamic healthcare networks as future work. Neither adapts at runtime or addresses privacy. **PQC performance.** Kampanakis and Childs-Klein [8] measure the time-to-last-byte impact of ML-KEM/ML-DSA TLS, finding overhead of up to roughly 32% on handshakes in low-bandwidth settings and shrinking with payload size; this motivates our focus on small telemetry packets and constrained links, but they study static configurations. **Adaptive PQC selection.** AdaptiveQKE [9] selects hybrid ML-KEM groups per

TLS 1.3 connection from measured RTT and device limits (a student prototype with RSA certificates, emulated on one host); CAAP [10] selects KEM/signature profiles for 6G vehicular links from predicted channel state in trace-driven simulation. Neither adapts privacy parameters. **Adaptive IoMT security.** Q-PRADAX [11] combines lattice cryptography, zero-knowledge proofs and Q-learning for key management and clustering at the edge; differential privacy is not part of it, and no compliance floor is described. **Adaptive privacy.** ALPINE [12] maps channel, sensitivity, context and resource risks to a local-DP budget with a TD3 policy for mobile edge crowdsensing; it has no cryptographic dimension. Recent surveys list combining cryptographic protection with DP and runtime privacy-budget management as open directions [13].

Runtime-adaptive PQC selection is therefore *not* our claim; ours is the joint coupling of transport and privacy parameters under one budget with a floor for raw PHI. Table 1 summarises the comparison. Entries are judged from each work's abstract or available text and are not the result of a systematic review; a formal review remains future work.

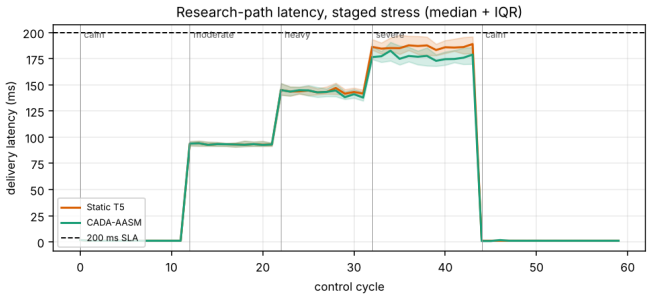


Figure 1: Research-path latency under staged stress (median, IQR over 30 trials).

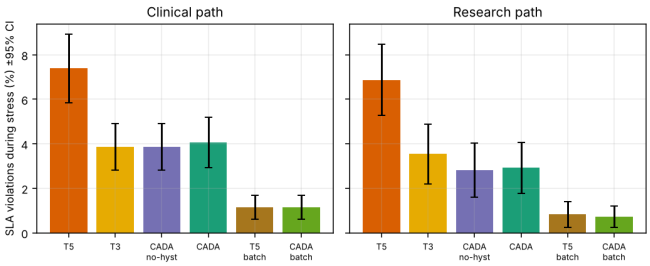


Figure 2: SLA violations during stress with 95% CI.

3 Design

Budget and steering. Each cycle the gateway measures RTT R and CPU utilisation C (%) and computes $L = 200 - R - 0.5C$. $L > 80$ ms selects Tier 5 (ML-KEM-1024, ML-DSA-87, AES-256-GCM, $\varepsilon = 0.1$, $K = 5$, $L_{div} = 3$); $40 < L \leq 80$ Tier 3 (ML-KEM-768, ML-DSA-65, AES-256-GCM, 0.5, 3, 2); $L \leq 40$ Tier 1 (ML-KEM-512, ML-DSA-44, ChaCha20-Poly1305, 1.0, 2, 2). A transition is committed only after the same different target appears on three consecutive cycles.

Dual-domain policy. The agile tier governs the de-identified research stream: Laplace noise scale Δ/ε on physiological samples and Mondrian [14] (K, L)-partitioning on EHR records. The raw clinical stream uses max(agile, 3), so PHI is never protected below NIST Category 3 irrespective of congestion. Researcher exports additionally enforce $K \geq 5$, $L \geq 3$ and are re-verified independently before release.

Hybrid channel. Key establishment combines X25519 and ML-KEM by HKDF over the concatenated secrets salted with the transcript hash; the server signs the transcript with Ed25519 *and* ML-DSA and both must verify. Packets are AEAD-protected with tier, session and sequence number as associated data and carry an Ed25519 signature; an ML-DSA signature over a hash chain of the epoch is attached every E packets ($E = 1$: per-packet PQ signature; $E = 8$: batch signing). Re-keying on a tier change is make-before-break.

4 Implementation

Python; `kyber-py`/`dilithium-py` (FIPS 203/204 reference code, not constant-time) and `cryptography`; Flask/Socket.IO console with role-based JWT access (admin, auditor, researcher, operator); hash-chained, HMAC-protected audit log; 59 automated tests covering controller invariants, crypto rejection of every tampered field, (K, L) verification and RBAC.

5 Evaluation

What is modelled. Cryptography, packet sizes, anonymisation and control logic are executed for real. Congestion is *emulated*: injected RTT, CPU load, loss and bandwidth, and a delivery model latency $= R +$ serialisation + queueing (fragments $- 1$) + one RTO on loss. PQ compute is not charged to per-packet latency (pure-Python code would measure the interpreter); only wire bytes are. Results therefore characterise the mechanism, not a hospital network.

Protocol. 30 paired seeds; each trial has 60 cycles: calm(12), moderate(10), heavy(10), severe(12), calm(16). Baselines: static T5, static T3, CADA without hysteresis, each with per-packet PQ signatures; plus batch-signing variants. Paired Wilcoxon signed-rank tests.

Table 1: Positioning against related work (✓ = addressed, – = not addressed in the text we read).

Work	PQC	Privacy (DP/anon.)	Runtime-adaptive	Crypto+privacy jointly	Compliance floor
NIST CSWP 39 [6]	✓	–	–	–	–
Alif et al. [7]	✓	–	–	–	–
Kampanakis & Childs-Klein [8]	✓	–	–	–	–
AdaptiveQKE [9]	✓	–	✓	–	–
CAAP [10]	✓	–	✓	–	–
Q-PRADAX [11]	✓	–	✓	–	–
ALPINE [12]	–	✓	✓	–	–
Agile-HQ-PQC (this work)	✓	✓	✓	✓	✓

Table 2: Staged-stress evaluation, 30 paired trials, mean ± 95% CI.

Metric	Static T5	Static T3	CADA, no hyst.	CADA-AASM	T5 + batch	CADA + batch
Clinical viol. (stress)	7.4% ± 1.5	3.9% ± 1.0	3.9% ± 1.0	4.1% ± 1.1	1.1% ± 0.5	1.1% ± 0.5
Research viol. (stress)	6.9% ± 1.6	3.5% ± 1.3	2.8% ± 1.2	2.9% ± 1.1	0.8% ± 0.6	0.7% ± 0.5
Clinical p95 (ms)	195.7 ± 2.5	187.3 ± 1.9	187.4 ± 1.9	187.7 ± 2.1	172.6 ± 1.6	173.7 ± 1.7
Research p95 (ms)	197.8 ± 7.8	187.1 ± 2.7	185.1 ± 3.5	184.2 ± 2.8	172.2 ± 1.7	173.0 ± 1.9
Mean wire bytes	5030.2 ± 0.1	3712.2 ± 0.1	4546.9 ± 0.1	4609.9 ± 21.3	943.0 ± 0.1	821.6 ± 4.2
Handshakes/trial	2.0 ± 0.0	2.0 ± 0.0	10.9 ± 0.6	6.4 ± 0.2	2.0 ± 0.0	6.4 ± 0.2
Tier changes/trial	0.0 ± 0.0	0.0 ± 0.0	6.9 ± 0.6	2.4 ± 0.2	0.0 ± 0.0	2.4 ± 0.2

Table 3: Paired Wilcoxon tests, CADA-AASM minus baseline (per-packet PQ signatures).

Baseline	Metric	mean diff	Wilcoxon p
T5	clin. viol. (pp)	-3.33	6.0e-05
T5	res. viol. (pp)	-3.96	2.9e-05
T5	res. p95 (ms)	-13.54	1.9e-09
T5	tier changes	+2.40	5.9e-07
T3	clin. viol. (pp)	+0.21	1.6e-01
T3	res. viol. (pp)	-0.62	5.8e-02
T3	res. p95 (ms)	-2.84	2.0e-07
T3	tier changes	+2.40	5.9e-07
no hyst.	clin. viol. (pp)	+0.21	1.6e-01
no hyst.	res. viol. (pp)	+0.10	7.1e-01
no hyst.	res. p95 (ms)	-0.84	7.2e-01
no hyst.	tier changes	-4.47	2.3e-06

Table 4: Sweep: CADA minus static-T5 SLA-violation rate (percentage points), constant severe RTT/CPU stress.

loss \ bw	20 Mbps	5 Mbps	2 Mbps	1 Mbps
0%	+0.0	+0.0	-2.1	-44.8
0.5%	+0.0	+0.0	-4.2	-45.8
1%	-1.0	-1.0	-4.7	-44.3
2%	-1.0	-1.0	-4.7	-43.2

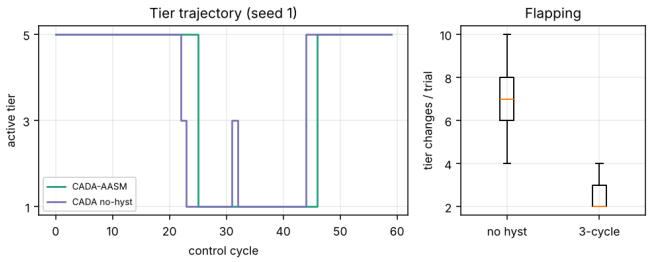


Figure 3: Tier trajectory and flapping with and without the persistence filter.

6 Results and Discussion

Against static Tier 5 (per-packet PQ signatures), steering lowered SLA violations during stress from 7.4% to 4.1% (clinical) and 6.9% to 2.9% (research) and p95 latency by 8–14 ms (Table 2,3, Figs. 1,2), at the cost of about 4.4 extra handshakes per trial.

Against static Tier 3 the violation rates were not significantly different (clinical $p = 0.16$, research $p = 0.058$). The value of steering here is not lower latency than a permanently weaker suite but obtaining the strongest suite and the strongest privacy parameters (mean $\varepsilon = 0.37$, $K = 4.1$ over the trial) whenever the budget allows, instead of a fixed compromise.

Hysteresis cut tier changes from 6.9 to 2.4 per trial and handshakes from 10.9 to 6.4 with no significant change in violations. We did not observe a latency benefit from hysteresis; its benefit is stability and re-key cost.

The clinical floor held in all trials (minimum clinical tier 3). Because the floor prevents the clinical path from reaching Tier 1, clinical violations under steering equal those of static Tier 3 (4.1% vs 3.9%); this is the price of the compliance invariant.

Negative result: batch signing. Amortising the ML-DSA signature over eight packets reduced mean wire size from about 5.0 kB to 0.9 kB and violations to 1.1%

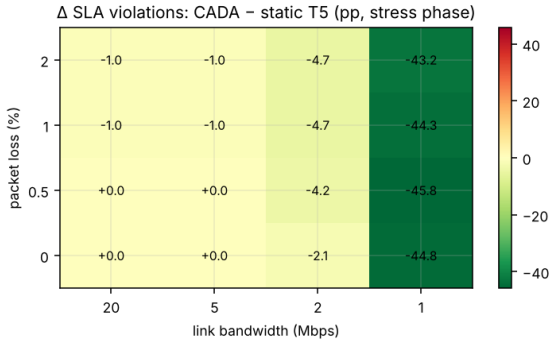


Figure 4: Where steering helps: bandwidth×loss sweep.

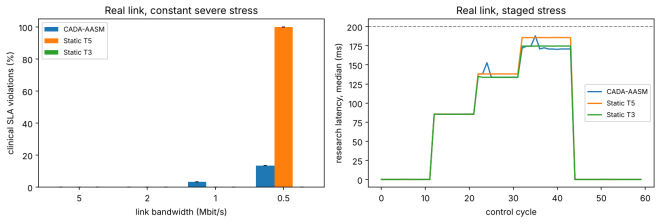


Figure 5: Real-link validation (namespaces + kernel tbf). Left: clinical SLA violations under constant severe stress vs bandwidth. Right: median research latency under staged stress.

with or without steering (Table 2); with batch signing, steering showed no significant latency benefit (Table 3) and slightly worse clinical p95 (+1.1 ms, $p = 0.0497$). Thus the latency argument for steering depends on the signature strategy; the privacy-adaptation argument is independent of it.

Sensitivity. Steering helped little or not at all at ≥ 5 Mbps, modestly at 2 Mbps (-2 to -5 pp) and strongly at 1 Mbps (≈ -45 pp, Table 4), where a 5 kB packet cannot be serialised inside the budget. The mechanism is therefore most relevant to bandwidth-constrained IoMT links (cellular, low-power radio, congested Wi-Fi).

Real-link validation. To test the emulated model we ran the same staged schedule over two Linux network namespaces joined by a veth pair with kernel token-bucket shaping, real TCP, the project's actual packet bytes, an echo-probe RTT over the shaped link and real CPU load (4 repetitions per cell; propagation delay is a stated receiver hold and loss is not modelled because kernel netem was unavailable). Results are in Fig. 5. With staged stress no configuration violated the SLA and static Tier 5 had only ≈ 5.6 ms higher p95 latency than CADA or Tier 3 (equal with batch signing): *the emulated gain over static Tier 5 is not reproduced on a real link at* ≥ 2 *Mbit/s*, so it was driven by the emulator's fragment-queueing and loss terms rather than wire bytes alone. Under constant severe stress, size matters only at the lowest rates: at 0.5 Mbit/s static Tier 5 violated the SLA on every cycle, CADA on 13% (it starts at Tier 5 and needs three cycles and a rekey to step down) and static Tier 3 on none; at 1 Mbit/s CADA (3.3%) was slightly worse than both statics. Native liboqs timings (ML-DSA-65 sign ≈ 0.09 ms versus ≈ 94 ms for the pure-Python code) confirm that wire size, not compute, is the cost that matters. With four pairs the smallest attainable Wilcoxon p is 0.125, so these are descriptive results.

7 Limitations

In the main evaluation congestion and the latency model are assumptions (the real-link validation covers bandwidth shaping and real RTT/CPU only); PQ code is a non-constant-time reference implementation; stress presets are author-chosen; Laplace sensitivity Δ is a modelling choice; Mondrian gives only k-anonymity and distinct ℓ-diversity; variable privacy parameters tied to network state require data-governance review; the related-work comparison is from abstracts and available text, not a systematic review or prior-art search. Kernel `netem` packet loss and delay, a multi-host virtual-machine testbed with a native liboqs TLS stack, and a user study with clinicians are future work.

8 Conclusion

Treating transport strength and privacy strength as one latency-budget-driven control problem is implementable, keeps a compliance floor for raw PHI, and measurably reduces SLA violations relative to static maximum security on constrained links, but under our model it does not beat a well-chosen static Tier 3 on latency and becomes latency-neutral once PQ signatures are batched. On a real shaped link its latency benefit appears only on very thin links, and a well-chosen static Tier 3 is as good there. Its distinctive contribution is the joint, safe adaptation of cryptographic and privacy parameters, not a latency win.

References

[1] National Institute of Standards and Technology, "FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard," tech. rep., NIST, 2024.

[2] National Institute of Standards and Technology, "FIPS 204: Module-Lattice-Based Digital Signature Standard," tech. rep., NIST, 2024.

[3] C. Dwork, F. McSherry, K. Nissim, and A. Smith, "Calibrating noise to sensitivity in private data analysis," in *Proc. TCC*, 2006.

[4] L. Sweeney, "k-anonymity: A model for protecting privacy," *Int. J. Uncertainty, Fuzziness and Knowledge-Based Systems*, vol. 10, no. 5, pp. 557–570, 2002.

[5] A. Machanavajjhala, D. Kifer, J. Gehrke, and M. Venkitasubramaniam, "ℓ-diversity: Privacy beyond k-anonymity," *ACM Trans. Knowl. Discov. Data*, vol. 1, no. 1, 2007.

[6] E. Barker, L. Chen, D. Cooper, D. Moody, A. Regenscheid, M. Souppaya, W. Newhouse, R. Housley, S. Turner, W. Barker, and K. Kent, "Considerations for achieving cryptographic agility: Strategies and practices," Tech. Rep. CSWP 39, NIST, 2025. Verify current version: page lists the Dec 2025 edition as withdrawn 29 Jun 2026 and superseded by CSWP 39upd1.

[7] A. Alif, K. F. Hasan, B. Palaniswamy, and M. M. Islam, "A framework for post quantum migration in IoT-based healthcare systems." arXiv:2604.15584, 2026.

[8] P. Kampanakis and W. Childs-Klein, "The impact of data-heavy, post-quantum TLS 1.3 on the time-to-last-byte of real-world connections," in *Proc. MADweb (NDSS Workshop)*, 2024. IACR ePrint 2024/176.

[9] H. Ajjour, W. Abdalaal, H. Nasrallah, and F. Rajab, "AdaptiveQKE: Adaptive selection of hybrid post-quantum key-exchange groups for TLS 1.3." GitHub HebaAj/AdaptiveQKE (B.Sc. graduation project, UCAS; not peer reviewed), 2025.

[10] P. Sengupta, M. Raikwar, S. Maharjan, F. Eliassen, and Y. Zhang, "Adaptive quantum-safe cryptography for 6G vehicular networks via context-aware optimization." arXiv:2602.01342, 2026.

[11] S. Ben Othman and G. Kumar, "Quantum-resilient and adaptive multi-region data aggregation for IoMT using zero-knowledge proofs and edge intelligence," *Scientific Reports*, vol. 15, no. 37176, 2025. Framework named Q-PRADAX.

[12] G. Cheng, S. Liu, X. Zhao, Y. Chen, J. Huang, L. Kong, and S. Deng, "ALPINE: Closed-loop adaptive privacy budget allocation for mobile edge crowdsensing." arXiv:2510.17162, 2025.

[13] Z. Zaman, P. Gauravaram, M. Hassan, S. Jha, and W. Hu, "Privacy-preserving machine learning for IoT: A cross-paradigm survey and future roadmap." arXiv:2603.13570, 2026.

[14] K. LeFevre, D. J. DeWitt, and R. Ramakrishnan, "Mondrian multidimensional k-anonymity," in *Proc. IEEE ICDE*, 2006.